





Crack in the Shell

How Access Brokers Are Cracking Open Our Industry

Joshua Brunner / OT-Quest

Our industry has always trusted the shell. Air gaps, proprietary protocols, "nobody understands our systems but us" that's been our armor for twenty years. It's why a water plant operator could go a whole career without thinking about a firewall rule.

That shell has a crack in it now, and it's not the crack we trained for. We trained to watch for someone who understands SCADA. We didn't train to watch for someone who doesn't need to.

The guy who breaks in isn't the guy who hurts you

There's a kind of criminal now whose entire job is the break-in itself. They don't care what's on the other side of the door. They find a way in a VPN with no MFA, a stolen password, an old web server nobody patched and then they sell that door. Not the data behind it, not the system behind it. Just the door.

This is called an Initial Access Broker, or IAB. Think of it like someone who picks locks for a living and sells the keys on a corner nobody walks down. They never go inside. They don't need to know what's in your house. Somebody else buys the key and decides what to do with it.

For us, that's the part that should keep you up at night. **The person who broke in had zero interest in your plant. The person who bought the key might have built their entire career around plants exactly like yours.**

Two very different buyers, two very different nightmares

Once that door is sold, what happens next depends entirely on who's buying.

Buyer One: The Financially Motivated Encryptor

They want fast money. They drop ransomware, encrypt everything they can reach, and leave a note. Here's the thing operators need to sit with: most of the time, they never touch your PLCs. They don't need to. They encrypt the Windows server running your HMI, your historian, your asset management software, your engineering workstations, the IT-side stuff that your process depends on without you even thinking about it day to day. Your control loop might be fine. Your ability to see it, log it, or operate it isn't. The plant goes down anyway.

Buyer Two: The Patient Reconnaissance Actor

This one isn't in a hurry. They buy the same kind of access and do almost nothing visible. No ransom note. No encrypted files. The pattern is reported in cases like this: they sit, watch, and learn how a process actually works, which RTU talks to which valve, how control loops respond, and where the real choke points are. They're not stealing your data. They're building a map for later, for a moment when disrupting a process is worth more to them than money ever could be. This is the patient threat, and it's the one our usual incident response training doesn't catch, because nothing looks broken.

This isn't a hypothetical I'm inventing. Dragos has reported activity consistent with exactly this access-broker model, one group's footprint focused on initial compromise of edge devices (VPN appliances, file-transfer tools, that kind of internet-facing gear), with follow-on activity in the same environments suggesting a different, more OT-focused operational objective. Whether every step of that handoff was directly observed or pieced together from correlated activity, I can't say with certainty but the pattern itself, two actors with two different skill sets touching the same intrusion, is documented and real.

Why our shell is exactly the wrong shape for this

Here's the operator's truth: nobody likes saying out loud: most of us are still running flat networks. SCADA, the pumping cabinet, the engineering workstation, somebody's laptop all sitting on the same address range, all able to see each other. I've documented this myself at my own facility.

A flat network means the IAB doesn't need to know a single thing about water treatment, power distribution, or process control to hand a buyer everything they need. The buyer doesn't need skill to get from "stolen IT credential" to "standing in front of your PLC." Your network architecture does that work for them, for free.

This is the actual lesson hiding inside the IAB story: sophistication is no longer required at every stage of the attack chain. It used to be true that ICS was safe because attacking it

took specialized knowledge most criminals didn't have. That protection is thinning — not because criminals got smarter about process control, but because the broker model lets specialized OT knowledge exist just once, downstream, in whoever's buying. Everyone upstream of that, the password thief, the VPN scanner, the guy selling access on a forum never has to understand a single thing about what they're selling into. Sophistication still matters once someone's actually trying to manipulate a process or stay hidden in OT for the long haul that part hasn't changed. What's changed is that it no longer has to exist at the front door.

Someone could fairly point out that access brokers aren't new; they've been part of the cybercrime economy for years. That's true. What's new isn't the broker model itself; it's how often that model now reaches into OT-adjacent environments that used to be considered too obscure to bother with.

What this is, and what this isn't

I want to be straight with anyone reading this, operator to operator: this isn't a "the sky is falling, everyone's coming for your plant" paper. Most ransomware hits are still just businesses getting hit like any other business opportunistic, not personal, not OT-specific. Not every incident in the news is an OT incident, even when an industrial company's name is in the headline. I'm not going to point at a specific company and tell you a story about exactly how their access got sold, because in most public cases, nobody outside the investigation actually knows that for certain, including me.

What I am telling you is that multiple sources across multiple sectors point to the same pattern, and it's growing. Real advisories. Real incidents where OT-supporting systems went down because of IT-side encryption. Documented cases of brokers handing access to specialized follow-on actors. The shell our industry has relied on being too obscure, too specialized, too boring to be worth a sophisticated attacker's time doesn't hold the way it used to, because the sophisticated attacker doesn't have to be the one who breaks in anymore.

Initial Access Brokers don't care what your process controls protect; they only care that the door can be sold.

What actually closes the gap

None of this requires us to become cybersecurity PhDs. It requires the boring stuff, done consistently:

- **MFA on every remote access point.** Yes, that annoying thing IT makes you prove you are from your phone that's helping. Especially on vendor and contractor VPNs, that's consistently where the door gets left open.
- **Clean desk policy.** You don't leave your phone password on a sticky note on the monitor. Don't leave the SCADA one there either. Sounds obvious until you walk into a control room and count how many passwords are sitting in plain sight.
- **Actually segment IT from OT.** Not "we have a firewall somewhere." Actual enforced separation, the kind where someone with your IT password can't see your SCADA network at all.
- **Don't let stolen passwords live forever.** Session timeouts matter more than people think, because a lot of this access is built on credentials stolen months before anyone uses them.
- **SCADA access should clock in and clock out, no exceptions.** Every login needs to be tied to a specific person, and every session logged starts to finish. Look, we all know the operational reality: sharing a generic console login like "Operator1" has been the historical norm so no one wastes critical seconds logging in during an emergency response. But modern identity setups, badge-taps, quick PIN switches change the game. This isn't about catching operators doing their job; it's about protecting you. If something goes sideways at 2 AM on a Tuesday, an undeniable record proves exactly who was in the system and what they touched. Non-repudiation protects the operator from being wrongly blamed just as much as it protects the plant floor.

The lock-picker doesn't care about your plant. But somebody buying that key very well might. Our job is making sure that when the door gets picked and at this point, assume it will be there's nothing valuable sitting right behind it.

This isn't hypothetical

In August 2019, 23 Texas municipalities went down in a coordinated REvil attack. The door wasn't a SCADA exploit, it was one managed service provider's remote access getting compromised. The towns recovered without paying, thanks to fast detection and offline backups. The MSP never recovered its customer base.

In June 2026, Mackay Sugar in Queensland lost two of three mills mid-harvest following a ransomware incident that disrupted operations across the region. Roughly 1,300 farms felt the impact. Public reporting has identified the ransomware group involved, but the precise initial access vector has not been publicly disclosed. I'm not going to pretend otherwise.

What we do know is that across the broader ransomware landscape, many intrusions continue to begin with ordinary credential theft, exposed remote access services, and other common enterprise weaknesses rather than custom ICS exploits. Mackay Sugar is a reminder that industrial disruption often does not require an industrial exploit.

Different sectors, different years, same mechanism: a door gets picked, somebody buys the key, and real people downstream feel it.

So what do you actually do

If you're reading this wondering what happens if the worst actually lands on your facility: call the authorities. Don't sit on it.

In Texas water, that's not optional; it's built into TCEQ Chapter 290, the public drinking water rules every Texas water system operates under. There's a reporting requirement, and TCEQ has a hotline for exactly this. I've built incident response plans around this rule myself. It's not theoretical to me; it's the thing I'd actually pick up the phone for.

The Texas Department of Information Resources (DIR) has resources too, beyond just water — coordination, response support, the same playbook that helped those 23 municipalities get back online without paying a ransom in 2019.

If you're outside Texas or outside water, your sector has its own version of this. Find out what it is before you need it, not during.

Sources

- StateScoop, *"How Texas used its disaster playbook after a huge ransomware attack"* (Oct. 2019) — reporting on the NASCIO panel with Texas CIO Todd Kimbriel and CISO Nancy Rainosek
- *Click Here* podcast, Episode 1, hosted by Dina Temple-Raston — on the 2019 Borger, TX attack
- Rescana, *"Ransomware Attack on Mackay Sugar Disrupts Australian Mills: Cybersecurity Incident Analysis and Lessons Learned"* (June 2026)
- SecurityWeek, *"Ransomware Attack Shuts Down Mills of Australia's Second-Largest Sugar Producer"* (June 2026)
- KELA threat intelligence reporting on the Storm-2697 ("The Gentlemen") internal chat log leak (May 2026)
- Dragos threat intelligence reporting on the SYLVANITE/VOLTZITE access-broker pattern

— Joshua Brunner, OT-Quest

Footnote: This piece started as a question I couldn't shake after an episode of Darknet Diaries. Sometimes the best research starts with a podcast and a long drive.